

Reporte ejecutivo de riesgos

Clinica privada ficticia - 120 empleados - aproximadamente 800 pacientes diarios

7	2	3	0
RIESGOS FORMALES	RIESGOS CRITICOS	PLANES DE ACCION	MITIGACIONES ACEPTADAS

Resumen ejecutivo

La evaluacion inicial identifica una exposicion elevada para la clinica: dos riesgos criticos y cinco altos afectan la confidencialidad de historias clinicas, la continuidad de la atencion y la capacidad de recuperacion ante incidentes. La prioridad inmediata es reducir la probabilidad de compromiso de cuentas y limitar el impacto de ransomware o fallas de recuperacion.

Se registraron los riesgos en SimpleRisk y se planificaron tres mitigaciones. Las mitigaciones permanecen en estado **Planificado**: su riesgo residual no fue aceptado porque los controles aun no fueron implementados ni verificados.

Top 5 riesgos por nivel

ID	Riesgo	Nivel	Impacto para la clinica	Respuesta prioritaria
R-01	Phishing y robo de credenciales	Critico 20	Acceso indebido a historias clinicas y facturacion.	MFA, filtro de correo y capacitacion.
R-02	Ransomware sobre historias clinicas y turnos	Critico 20	Interrupcion de la atencion y posible perdida de datos.	EDR, segmentacion y backups inmutables.
R-03	Consulta interna indebida de historias clinicas	Alto 15	Violacion de privacidad, sanciones y dano reputacional.	Minimo privilegio y auditoria de accesos.
R-04	Recuperacion fallida de copias de respaldo	Alto 15	Recuperacion tardia o imposible de servicios y datos.	Regla 3-2-1 y pruebas de restauracion.
R-05	Exposicion por configuracion insegura	Alto 15	Filtracion de datos personales y medicos.	Revisiones de configuracion y cifrado.

Lectura para el directorio: los cinco riesgos principales afectan informacion clinica o la continuidad de la atencion. El riesgo no se limita al area de TI; compromete la prestacion del servicio, la confianza de pacientes y el cumplimiento de obligaciones de privacidad.

Estado de los planes de accion

Plan	Riesgo	Responsable	Fecha objetivo	Presupuesto	Estado
PA-01 - MFA y phishing	R-01	Seguridad y TI	15/10/2026	\$500.000	Planificado
PA-02 - Ransomware y recuperacion	R-02	Jefatura de TI	15/11/2026	\$1.000.000	Planificado
PA-03 - Backups resilientes	R-04	Jefatura de TI	31/10/2026	\$500.000	Planificado

Presupuesto inicial estimado: **\$2.000.000**. Los montos son estimaciones de planificacion para priorizar decisiones; antes de contratar soluciones deben validarse con TI, compras y direccion.

Recomendaciones prioritarias

1	Aprobar MFA y capacitacion anti-phishing como medida inmediata para reducir el vector de entrada mas probable.
2	Financiar backups inmutables y una prueba de restauracion antes de aceptar cualquier riesgo residual asociado a ransomware.
3	Implementar segmentacion de red, EDR y gestion centralizada de parches para limitar propagacion y explotacion tecnica.
4	Revisar permisos y auditar el acceso a historias clinicas para detectar consultas sin necesidad asistencial.
5	Establecer revision mensual de riesgos altos y critica trimestral de la efectividad de los controles.

Decision solicitada al directorio

Aprobar la ejecucion de los tres planes priorizados, designar responsables de negocio y TI, y exigir evidencia de implementacion antes de aceptar mitigaciones o riesgos residuales. La proxima revision debe verificar el avance de MFA, backups y proteccion contra ransomware.

Hoja de ruta de 90 dias

Periodo	Hito esperado	Evidencia para seguimiento
Dias 0 a 30	Aprobar PA-01, activar MFA y comenzar capacitacion anti-phishing.	Cobertura MFA y registro de capacitacion.
Dias 31 a 60	Implementar EDR, segmentacion inicial y gestion de parches priorizados.	Inventario de equipos protegidos y parches aplicados.
Dias 61 a 90	Completar backups inmutables y ejecutar prueba integral de restauracion.	Acta de restauracion exitosa y tiempos de recuperacion.

Criterios de seguimiento

Indicador	Meta inicial	Frecuencia
Cobertura de MFA	100% de cuentas con acceso a sistemas clinicos	Semanal
Prueba de restauracion	Resultado exitoso documentado	Mensual
Riesgos altos y criticos	Revision de avance y evidencias	Mensual

Base del analisis: registro de siete riesgos especificos, matriz Classic de SimpleRisk y planes de mitigacion documentados en el repositorio de la entrega.